

Evaluación de Seguridad Ofensiva

My File Server 1

Resultados del penetration test realizado sobre el activo "My File Server: 1", presentados para su revisión por el Consejo Directivo.

Presenta: Magdalena Yesenia Tristán Rivera — 174702

Materia: CNO IV — Programación WAP · Grupo T37A

Docente: Mtro. Servando López Contreras

Fecha del engagement: 08–09 de marzo de 2026



Contexto del Engagement



Objetivo

Evaluar el nivel real de exposición del servidor de archivos corporativo "My File Server: 1" ante un atacante externo sin conocimiento previo del entorno.



Modalidad

Evaluación tipo **Caja Negra (Black Box)** — sin credenciales ni documentación interna proporcionada, simulando un atacante externo real.



Alcance

Un único activo en entorno de laboratorio controlado, segmento de red interno 192.168.0.0/24. Evaluación autorizada y acotada.



Duración

Engagement de 2 días (08–09 de marzo de 2026), ejecutado conforme al estándar internacional **PTES**.

Metodología Aplicada

Evaluación conducida bajo el estándar **PTES (Penetration Testing Execution Standard)**, marco de referencia reconocido en la industria.



Reconocimiento

Identificación del activo y su superficie expuesta en la red.



Enumeración

Análisis detallado de servicios, versiones y configuraciones.



Explotación

Aprovechamiento controlado de las debilidades identificadas.



Post-Explotación

Verificación del alcance real del acceso obtenido.



Reporte

Documentación técnica y ejecutiva de hallazgos e impacto.



Herramental

Suite estándar de la industria para pruebas de penetración.

Nivel General del Riesgo



El activo evaluado presenta un nivel de riesgo **CRÍTICO**. Un atacante externo, sin ningún conocimiento previo del entorno, logró obtener **control total del servidor (acceso root)** en el transcurso de una sola sesión de evaluación.

El vector inicial fue un simple error de administración — no se requirió ningún tipo de ataque sofisticado para comprometer por completo el activo.

Hallazgos Críticos

HALLAZGO 01 · CRÍTICO

Credenciales expuestas en un archivo de acceso público

Un archivo accesible desde el navegador, sin ninguna protección, contenía la contraseña del sistema en texto plano — permitiendo acceso autenticado inmediato a servicios internos del servidor.

HALLAZGO 02 · CRÍTICO

Sistema operativo desactualizado — escalada a control total

La versión del sistema operativo en uso contenía una vulnerabilidad pública y ampliamente documentada, que permitió escalar de un acceso básico a **control administrativo completo** del servidor.

Escenario del Impacto Empresarial

Si este mismo escenario ocurriera en un entorno de producción real, las consecuencias para el negocio incluirían:



Pérdida de datos

Exposición total de archivos, documentos y credenciales almacenadas en el servidor comprometido.



Exposición regulatoria

Posibles incumplimientos de protección de datos si el servidor almacena información de clientes o empleados.



Daño reputacional

Pérdida de confianza de clientes y socios ante un incidente de seguridad de este nivel.



Costo de remediación

Gastos de respuesta a incidentes, notificación, y posibles sanciones muy superiores al costo de prevención.

Matriz de Riesgo



Recomendaciones Estratégicas

01

Gestión de credenciales

Eliminar el almacenamiento de contraseñas en texto plano y establecer políticas de manejo seguro de credenciales en toda la organización.

02

Gestión de parches

Implementar un programa formal y recurrente de actualización de sistemas operativos y software crítico.

03

Endurecimiento de servicios

Revisar y restringir la configuración de todos los servicios expuestos a la red (acceso anónimo, permisos, autenticación).

04

Segmentación de red

Aislar activos críticos en segmentos de red controlados, limitando el movimiento lateral ante un compromiso inicial.

05

Monitoreo continuo

Establecer detección de intrusos y revisión periódica de logs para identificar actividad anómala a tiempo.

06

Pentesting recurrente

Programar evaluaciones de seguridad ofensiva de forma periódica, no solo como ejercicio puntual.

Roadmap de Remediación

INMEDIATO · 72 HRS	CORTO PLAZO · MES 1	MEDIANO PLAZO · MES 2-3	CONTINUO
• Eliminar archivo con credenciales • Actualizar sistema operativo • Revocar accesos no autorizados	• Deshabilitar accesos anónimos • Migrar a protocolos seguros • Forzar autenticación en todos los servicios	• Endurecimiento general de servidores • Segmentación de red • Políticas de cabeceras y configuración	• Monitoreo y detección de intrusos • Gestión formal de parches • Pentesting periódico

Conclusión Ejecutiva



La evaluación confirma que el activo "My File Server: 1" se encuentra en un estado de **exposición crítica**. Un único error de administración —credenciales en texto plano, accesibles públicamente— fue suficiente para derivar en el compromiso total del servidor, sin que se requirieran técnicas de ataque sofisticadas.

Se recomienda atender las acciones inmediatas en un plazo no mayor a 72 horas, y adoptar las recomendaciones estratégicas como parte de la postura de seguridad continua de la organización.